

Case Study: What the 2024 CrowdStrike Glitch can Teach Us About Cyber risk.

Ezeoma Igwe

810408

California Baptist University

Information Technology Management

February 3, 2026.

Executive Summary

This case study primarily focuses on the CrowdStrike glitch that occurred during software update which caused a global IT outage that affected millions of systems running the Falcon security sensor. This glitch resulted from a failure in CrowdStrike's internal testing process and validation. The Outage resulted in losses and lawsuits filed against CrowdStrike which led to huge payouts. Some industries affected by the outage include government agencies, healthcare, retails and aviation companies such as Delta. Although the CrowdStrike incident was not an actual cyberattack, it helps organizations determine the "what-if" potential downstream business impact of a cyberattack at any supply chain. CrowdStrike strengthened its testing and deployment policies while businesses firm reevaluate their dependencies on third-party security software.

Introduction

The CrowdStrike glitch is one of the costliest outages that have occurred in the era of information technology. On the 19th of July 2024, CrowdStrike performed a routine software update which resulted in technical issues leading to disruption across the multiple critical sections of the global economy including aviation such as Delta, healthcare, retail services, emergency units like 911 calls record and government agencies. The incident was cleared of not being a cyber-attack, but it exposed critical deficiencies in software management, third-party governance and quality assurance. This case study examines the operational, technical and governance details of the outage and review its implications for the organizational resilience. The operational impact of this tragic incident is compared to that of a major security breach.

The CrowdStrike outage illustrates that cybersecurity confines not only protection against dangerous cyber threats but also ability to provide defensive technologies too. This case shows how errors in cybersecurity tools can undermine core security goals, especially system and information availability and advocates the importance of implementing risk management, resilience and secure software deployments into cybersecurity practices. The Incident also corresponds with multiple functions of the National Institute of Standards and Technology (NIST) cybersecurity framework. The Identify functions reveals shortcomings in third-party and supply chain risk identification. The insufficient software change management, validation and testing process incapacitated the protect function. The challenges in the respond and recover functions were exposed due to prolonged service restoration and heavy dependance on manual maintenance.

This case study aligns with system security due to the outage underscoring risks associated with software operating systems. CrowdStrike's endpoint agent required a deep

system access to its security functions; unfortunately, this design increased the impact of the software error, leading to global system failure. This highlights the need for increased testing, fault tolerance, fail-safe design for highly sensitive systems. Overall, the CrowdStrike's case examines the interconnected link with cybersecurity, system security, and government frameworks. It reinforces the view that cybersecurity risk goes above and beyond external threats to include internal system failures and vendor reliance, illustrating the importance of comprehensive risk management and efficient system design.

Analysis and Evaluation

The CrowdStrike incident exposed major operational risks that were not mitigated during the outage. System downtime was a major consequence of the outage, millions of Information Technology (IT) systems were not operational, due to unplanned failure. The endpoints became inaccessible, disabling personnels from accessing critical systems and performing routine operations. This situation stopped essential services and caused critical operational impact across affected departments. Another operational risk area was the heavy reliance on manual recovery. When the automated update triggers a manual recovery process, it establishes a surge failure that impacts every corner of an organization. The need for physical intervention across multiple endpoints created a bottleneck that overwhelmed the IT resources. The reputation of CrowdStrike was negatively affected by this incident, this was an operation risk that involved hard financial consequences. Customers lost their faith in CrowdStrike provider's reliability, leading to massive financial penalties, customer churn and long-term damage to brand equity. Although the backlash was high, the company's strong transparency with the customers enabled them to stabilize.

A peer reviewed study titled *Development of a Quantitative Assessment Algorithm for Operational Risk in Mining Engineering* (Nevskaya et al., 2025) introduces a simulation-based approach for examining operational risks in ore deposits development under conditions of uncertainty. It identifies critical risk factors through risk classification and mathematical modelling. This article aligns with the CrowdStrike incident, the simulation-based risk assessment method presented in the article provides a useful analysis of understanding the CrowdStrike outage. Just as conveyor shutdowns were shown to reduce annual mine revenue by 11.23%, the CrowdStrike failure revealed how a software update to a widely deployed endpoint agent could simultaneously disrupt millions of systems. Both cases illustrate the limitations of static risk registers and the importance of modelling low-probability, high-impact events. Another significant similarity is that system reliability is undermined not by external threats, but by internal operational failures that propagate rapidly due to system interference. The CrowdStrike incident mirrors the mining conveyor case by demonstrating how failures in a single critical subsystem can cascade into large-scale operational and financial losses, highlighting the value of simulation-based risk assessment and resilience-focused system design.

The CrowdStrike incident highlighted a fundamental technical risk alignment with modern cybersecurity solutions; their need for high-privilege access. Effective protection against extreme threats requires tools like CrowdStrike Falcon to run at the lowest levels of the operating system. The most significant technical risk is that CrowdStrike operates in Kernel Mode which has no safety net. The term “no safety net” indicates that if code in the Kernel crashes, the entire operating system must stop to prevent data corruption, resulting in a Blue Screen of Death (BSOD). A website titled *technical details of the Windows BSOD disaster due to CrowdStrike* (Shyam Su., 2024) examines the technical issues with the CrowdStrike incident and states

“Because the Falcon driver operates at the kernel level, the memory access violation caused a critical system fault. Windows detected this fault and, to prevent further damage or data corruption, it initiated a BSOD. The BSOD is a protective measure that halts the system to prevent further issues.”.

Another technical problem was insufficient pre-deployment testing and unsupervised update risk. The update passed standard checks but failed under precise real-world conditions, indicating technical gaps in testing across diverse environments. The absence of a native mechanism to stagger minor configuration updates means that a single technical defect propagated globally, creating a widespread single point of failure. Furthermore, encryption and authentication barriers occurred where technical security features designed to protect data resulted in obstacles to recovery. Many organizations stored their recovery keys on servers that were affected by the glitch, making it impossible to access the keys needed to fix the systems.

Some governance-related risks were exposed by the CrowdStrike incident which corresponded to policies, oversight and vendor management instead of fully technical issues. Insufficient vendor oversight was a huge problem since organizations relied heavily on CrowdStrike’s update process without independent validation, exposed inherent risks in managing third-party software. The Auto-Update policy gap often ensures that urgent fix stop hackers but failed to account for vulnerabilities. The Incident also illustrates that most software Service Level Agreements (SLA) often restrict vendor liability to the software cost, leaving organizations like Delta Air Lines vulnerable to losses in the hundreds of millions of dollars with tight legal options.

A peer reviewed study titled *Information Security Governance Simplified* (Fitzgerald & Peltier, 2016) guides security practitioners on establishing cost-effective information security

programs that meet government regulations. It clearly explains regulatory procedures and displays how to use control frameworks to create a robust governance structure. Furthermore, it outlines steps to safeguard organizational information and identifies the roles and responsibilities of all stakeholders, from the board of directors to end users, in ensuring security. This study aligns closely with NIST frameworks, such as the Cybersecurity Framework and SP 800-53, which provide effective approaches for detecting, identifying, protecting, responding to and recovering from cybersecurity risk. This is directly related to the CrowdStrike incident which exposes weakness in change management, vendor oversight and operational controls. Implementation of NIST-aligned governance practices, as the book enlightens, could help prevent such incidents through intensified risk assessment, structured change processes, and clear escalation and communication processes.

Though it may appear strange to relate a modern software outage to ancient writings, the CrowdStrike incident realistically reflect case about trust, human error, and dangers of concentrating power in a single source. Efficient planning and Foresight are not only business best practice but also biblical commands. *Proverbs 27:12* declares “The prudent see danger and take refuge, but the simple keep going and pay the penalty.” This applies directly to CrowdStrike as wise planning and foresight prevent unnecessary loss and ensure resilience. Simulation testing, phased rollouts, and contingency plans like what NIST framework signifies, reflect the biblical principle of preparing for foreseeable risks. Additionally, *Romans 14:12* declares “So then, each of us will give an account of ourselves to God.” This applies to CrowdStrike due to the incident exhibiting insufficient oversight in update deployment and vendor management which led to large-scale consequences. Well stabilized accountability structure could have mitigated the outage as leaders are responsible for their decisions.

Recommendation

To mitigate the risks exposed by the CrowdStrike incident, business firms need to move beyond a prevention only approach and embrace digital operational resilience. The goal is to ensure that even if a crucial security tool goes down, the impact is kept under control and recovery can take place with ease without resorting to a manual, time-consuming procedure. The outage can be prevented using an efficient technical strategy. Critical measures include staged development, enabling updates to be tested on small areas of the department before large scale full rollout and mechanism to reverse any problematic update quickly. The isolation of significant security components helps prevent a single failure from affecting the entire network system. Also, real-time monitoring is essential for early detection and rapid response to issues.

A peer reviewed study titled *Operational risk management: best practices in the financial services industry* (Chapelle, 2019) emphasizes on control testing being the responsibility of internal audit. The first line of defense is routine test and internal controls. It also advocates the need for an action plan to reduce the risk level of activity by improving controls. This study aligns with the CrowdStrike incident recommendation of implementing effective control testing to prevent errors and a plan to quickly contain bugged updates.

Efficient operational practices are critical to limiting the effectiveness of incidents like the CrowdStrike outage. Firms should develop incident response strategies that account for widespread endpoint failures, including situations where automated recovery is not possible. Clearly documented manual recovery process enables IT teams to restore systems quickly under adverse conditions. Strong Communication among IT, security and business teams provides timely decision-making and minimize conflicts of interest during incidents. Furthermore, routine

simulation exercises of low probability, high impact scenarios help identify operational weaknesses and strengthen operational resilience, reducing downtime and disruption.

Another peer reviewed study titled *Industrial robot system state simulation and risk utilization test environment design* (Jiang et al., 2025) identified how network-connected industrial robot systems face growing security risks, but existing testing environments lack the flexibility and realism needed for effective risk simulation. To address this issue, the study introduced Industrial Robot Systems State Simulation and Risk Utilization Test Environment (IRSSRE), a scalable, cost-effective framework for analyzing security risks in networked industries for robot systems. This study aligns closely with operational risk recommendations by focusing on resilience over pure prevention. While CrowdStrike exposed the dangers of over dependence on a single security control and the lack of realistic failure testing, IRSSRE addressed these issues by providing independent, scalable simulation of compromised and degraded system states.

Effective governance is essential to reducing the impact of the CrowdStrike incident. Firms should ensure that change management controls are available for critical updates, risk review, executive oversight and staged deployment needs. Adequate Vendor governance is equally important and should provide clear service agreements that define accountability and transparency around testing and implementation processes. The governance committee should properly ensure that risks are understood and addressed without prolonged delays. Aligning these practices with recognized frameworks such as NIST promotes oversight, accountability, and decision-making. Finally, *Proverbs 15:22* declares “Plans fail for lack of counsel, but with many advisers they succeed.” This verse emphasizes the importance of seeking guidance, collaboration and oversight when making decisions. It reinforces the need for structured review processes,

involvement of stakeholders, and advisory mechanisms to enable updates, policies and vendors actions are properly evaluated. This reduces the risk that a single poor decision will cause widespread operational shutdown.

In conclusion, the CrowdStrike incident demonstrates how technical failures, operational gaps, and governance weaknesses can combine to cause widespread organizational disruption. Effective risk management requires a comprehensive approach that integrates strong technical controls, robust operational procedures, and disciplined governance frameworks. Phased deployments, automated rollbacks, and real-time monitoring mitigate technical risks, while clear incident response plans, cross-team coordination, and simulation exercises enhance operational resilience. Governance measures such as structured change management, vendor oversight, and alignment with frameworks like NIST reduce systemic risk. Biblical principles of stewardship, accountability, and planning further emphasize the importance of responsible leadership and foresight in protecting critical systems and sustaining organizational trust.

References

- Bible Gateway. (2011). *New International Version*. Bible Gateway.
<https://www.biblegateway.com/>
- Chapelle, A. (2019). *Operational risk management: Best practices in the financial services industry*. John Wiley and Sons, Inc. <https://doi.org/10.1002/9781119548997>
- Fitzgerald, T., & Peltier, T. (2016). *Information Security Governance Simplified: From the Boardroom to the Keyboard* (1st ed.). CRC Press. <https://doi.org/10.1201/b11357>
- Jiang, W., Liu, X., Li, Z., Jin, X., Liu, W., & Li, Q. (2025). Industrial robot system state simulation and risk utilization test environment design. *Journal of Industrial Information Integration*, 48, 100953. <https://doi.org/10.1016/j.jii.2025.100953>
- Nevskaya, M., Shabalova, A., Nikolaichuk, L., & Kirsanova, N. (2025). Development of a Quantitative Assessment Algorithm for Operational Risks in Mining Engineering. *Resources*, 14(4), 53. <https://doi.org/10.3390/resources14040053>
- Shyam, S. (2024, July 20). Technical details of the Windows BSOD disaster due to CrowdStrike: The technical details of what caused the meltdown. Retrieved from <https://medium.com/@shyamsundarb/technical-details-of-the-windows-bsod-disaster->

